Lab Guide S06: Thiết lập mTLS Gateway với Nginx / Envoy & Kiểm soát Định danh Client

Mục tiêu: Cấu hình máy chủ Web TLS xác thực hai chiều (mTLS), kiểm soát truy cập dựa trên Subject Alternative Name của chứng chỉ khách hàng.

---

1. Cấu hình Nginx mTLS Gateway

Tệp cấu hình `nginx.conf`:

```
server {
    listen 8443 ssl;
    server_name api.kma.internal;

    ssl_certificate /etc/nginx/certs/server.crt;
    ssl_certificate_key /etc/nginx/certs/server.key;

    # Kích hoạt xác thực 2 chiều
    ssl_client_certificate /etc/nginx/certs/ca-chain.crt;
    ssl_verify_client on;
    ssl_verify_depth 2;

    location / {
        # Trả về thông tin định danh của Client Certificate
        default_type application/json;
        return 200 '{"status":"success","client_dn":"$ssl_client_s_dn","serial":"$ssl_client_seri
    }
}
```

---

2. Thử nghiệm Kết nối với Client Certificate

```
# 1. Truy cập không có chứng chỉ client (Yêu cầu bị từ chối)
curl -k https://localhost:8443/
# Kết quả mong đợi: 400 Bad Request (No required SSL certificate was sent)

# 2. Truy cập kèm chứng chỉ client hợp lệ
curl -k --cert certs/client.crt --key certs/client.key https://localhost:8443/
# Kết quả mong đợi: 200 OK kèm thông tin định danh
```

---

3. Tiêu chí Đánh giá Bài Lab S06

1. Máy chủ từ chối kết nối nếu không có chứng chỉ client hợp lệ.
2. Máy chủ phản hồi 200 OK khi cung cấp chứng chỉ client đúng chuỗi CA tin cậy.